

The background of the image features a dark blue gradient on the left, transitioning into a large, vibrant, abstract shape on the right. This shape is composed of overlapping curved segments in shades of orange, pink, and purple, creating a dynamic, modern aesthetic.

AWS re:Invent

NOV. 27 – DEC. 1, 2023 | LAS VEGAS, NV

NET 210

Securing your applications against web threats with AWS WAF

Harith Gaddamanugu

(he/him)

Sr. Edge Specialist Solutions Architect
Amazon Web Services

Igor Kushnirov

(he/his)

Sr. Edge Specialist Solutions Architect
Amazon Web Services



© 2023, Amazon Web Services, Inc. or its affiliates. All rights reserved.

AGENDA

What to expect from this chalk talk

1

What is AWS Web Application Firewall (AWS WAF) ?

2

Securing different application endpoints with AWS WAF

3

AWS WAF configuration

4

Q&A

AWS global threat intelligence

100M+

Daily observed potential threat interactions globally

~500K

Daily classified malicious activities globally

Source : <https://aws.amazon.com/blogs/security/how-aws-threat-intelligence-deters-threat-actors/>



© 2023, Amazon Web Services, Inc. or its affiliates. All rights reserved.

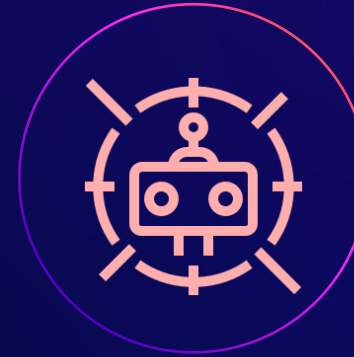
Common threats



DDoS attacks



Application level
threats



Bot attacks



AWS WAF

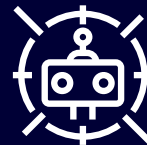
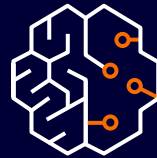
AWS Web Application Firewall

Monitors HTTP(S) requests forwarded to your protected web application resources



Flexible rule configuration

- Managed rules
- Rate limiting rules
- Multiple statement types
- Custom responses & header insertions



Intelligent threat mitigation

- AWS Bot Control
- AWS Fraud Control
- CAPTCHA or Challenge actions
- Client application integration



Logging & monitoring

- Native WAF dashboards
- Logging to Amazon S3
- Amazon Kinesis Data Firehose integration
- Log analysis with Amazon CloudWatch

AWS WAF

protects different application endpoints

Web applications and microservices

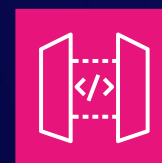


AWS Application Load Balancer



AWS App Runner

Serverless applications



Amazon API Gateway



Amazon AppSync

Authentication and authorization



Amazon Cognito



Amazon Verified Access

Web accelerated applications

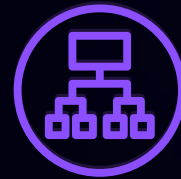


Amazon CloudFront

AWS WAF

protects different application endpoints

Web applications and microservices

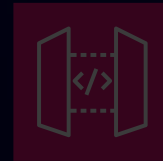


AWS Application
Load Balancer



AWS App Runner

Serverless applications

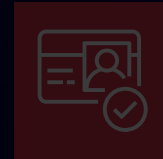


Amazon API Gateway



Amazon AppSync

Authentication and authorization

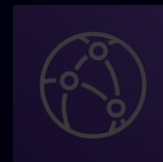


Amazon Cognito



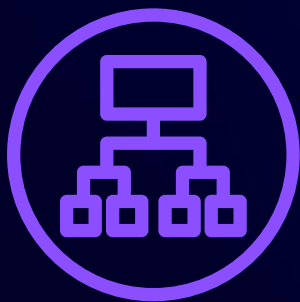
Amazon Verified
Access

Web accelerated applications



Amazon CloudFront

Web applications and microservices

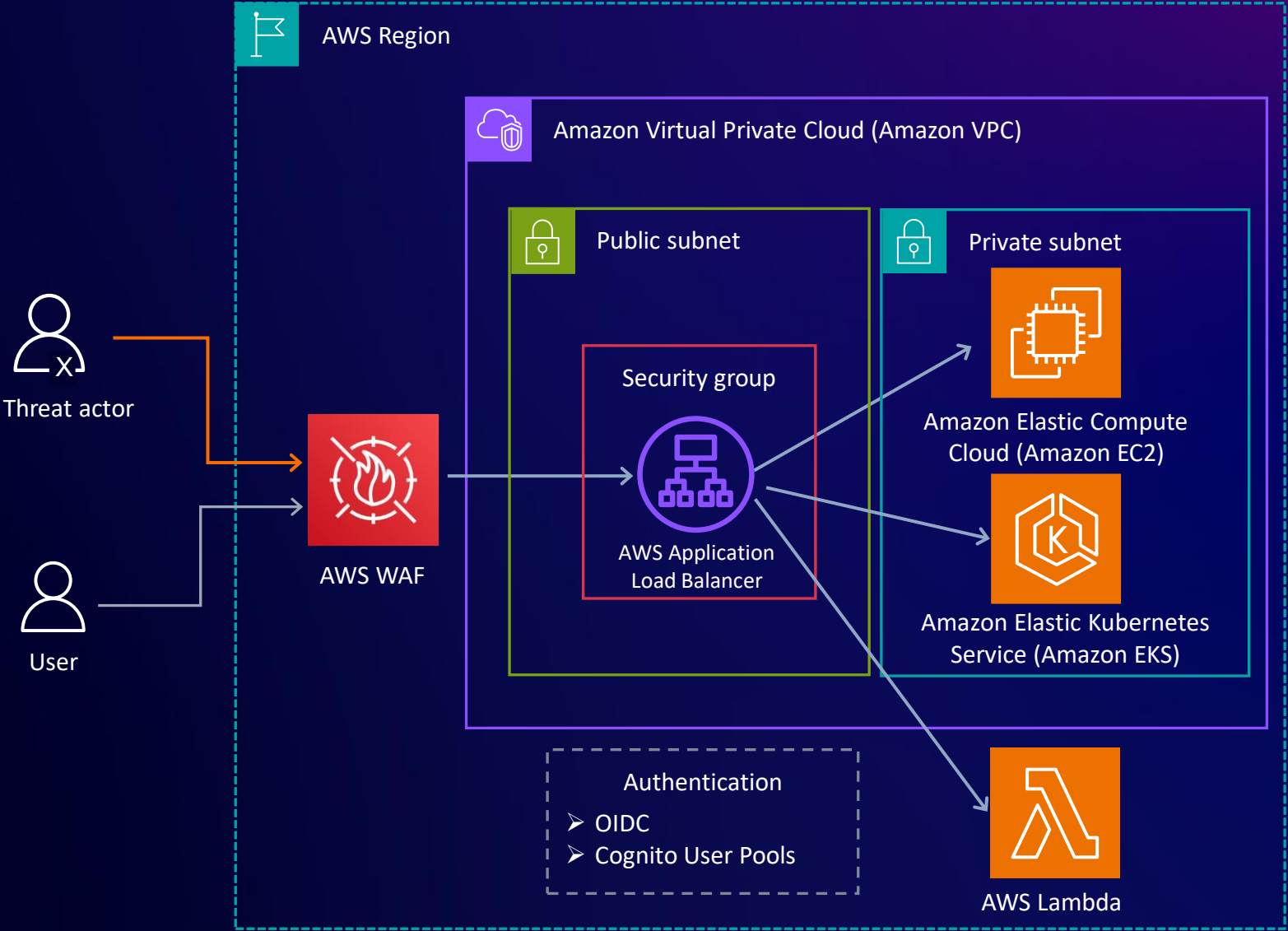


AWS Application Load Balancer

This is a load balancing option for the Elastic Load Balancing service that runs at the application layer



More on how to associate AWS WAF with Application Load Balancer



Web applications and microservices

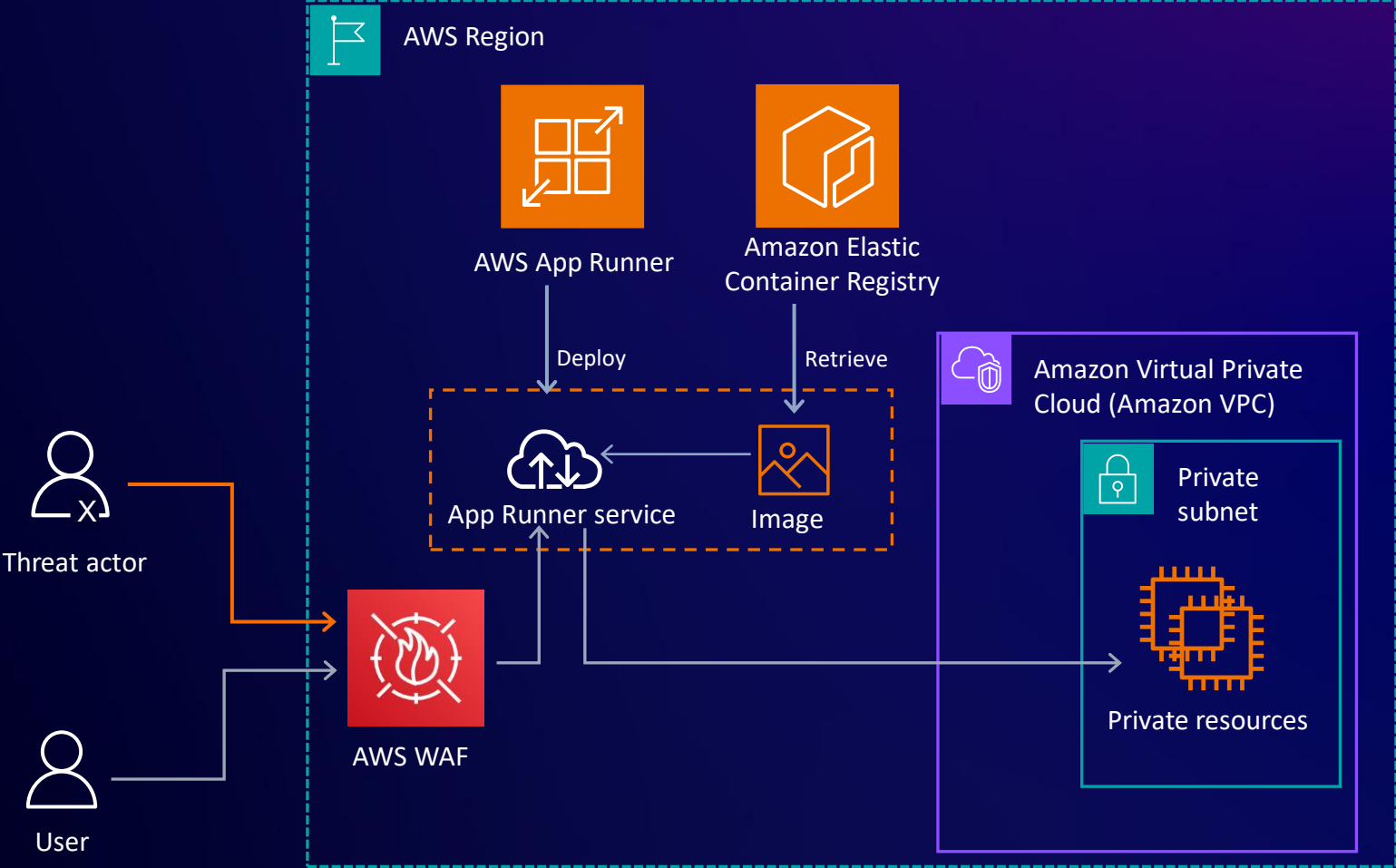


AWS App Runner

Fully managed container-based application service



More on how to associate
AWS WAF with AWS App Runner



AWS WAF

protects different application endpoints

Web applications and microservices

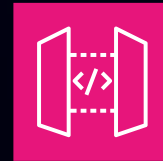


AWS Application Load Balancer



AWS App Runner

Serverless applications

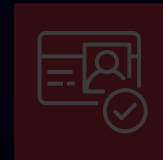


Amazon API Gateway



Amazon AppSync

Authentication and authorization

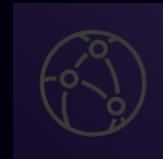


Amazon Cognito



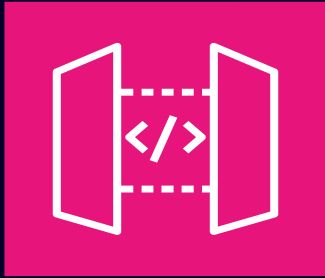
Amazon Verified Access

Web accelerated applications



Amazon CloudFront

Serverless applications



Amazon API Gateway

Fully managed service to help create, maintain, and secure API at any scale



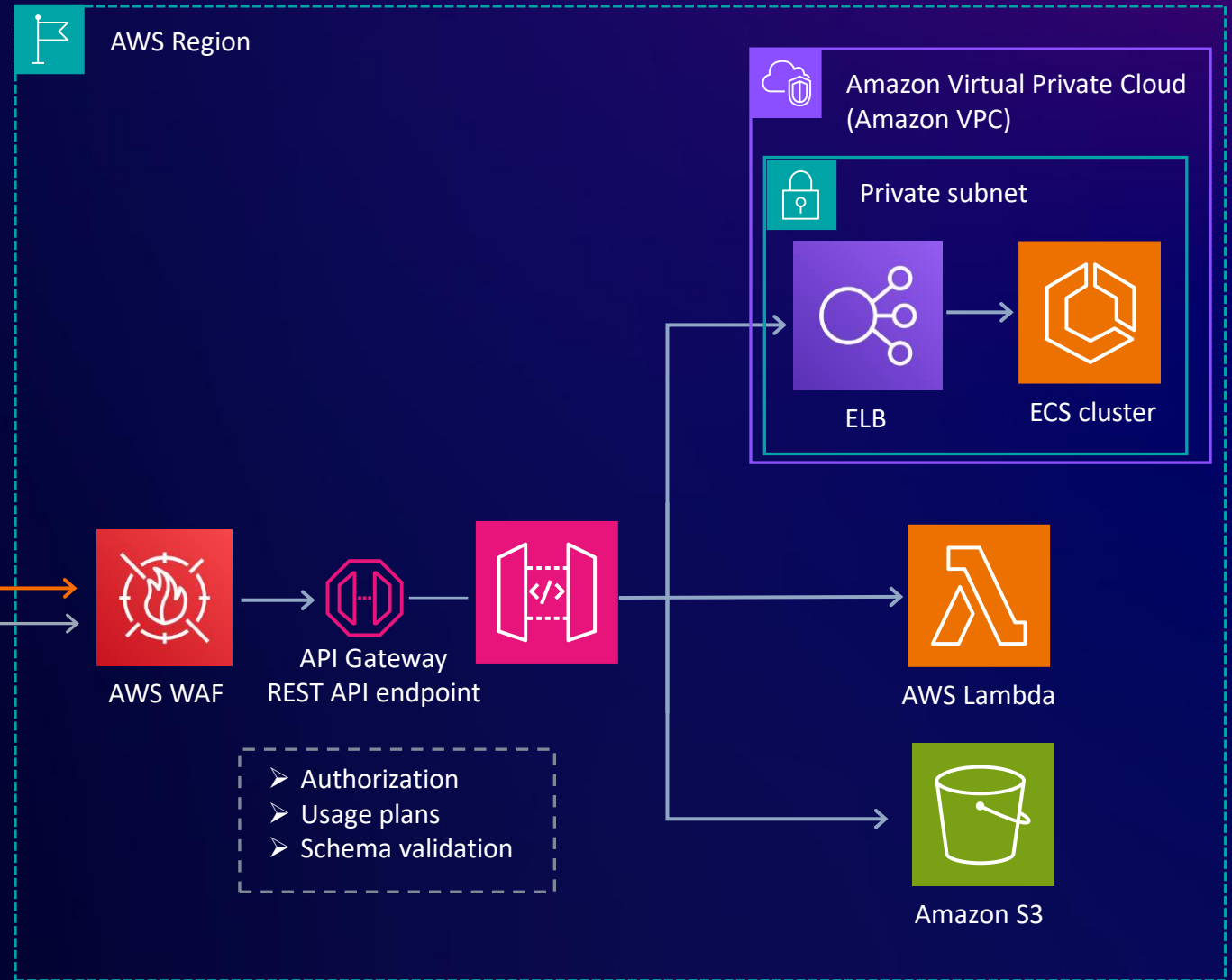
More on how to use
AWS WAF to protect your API



Threat actor



User



Serverless applications

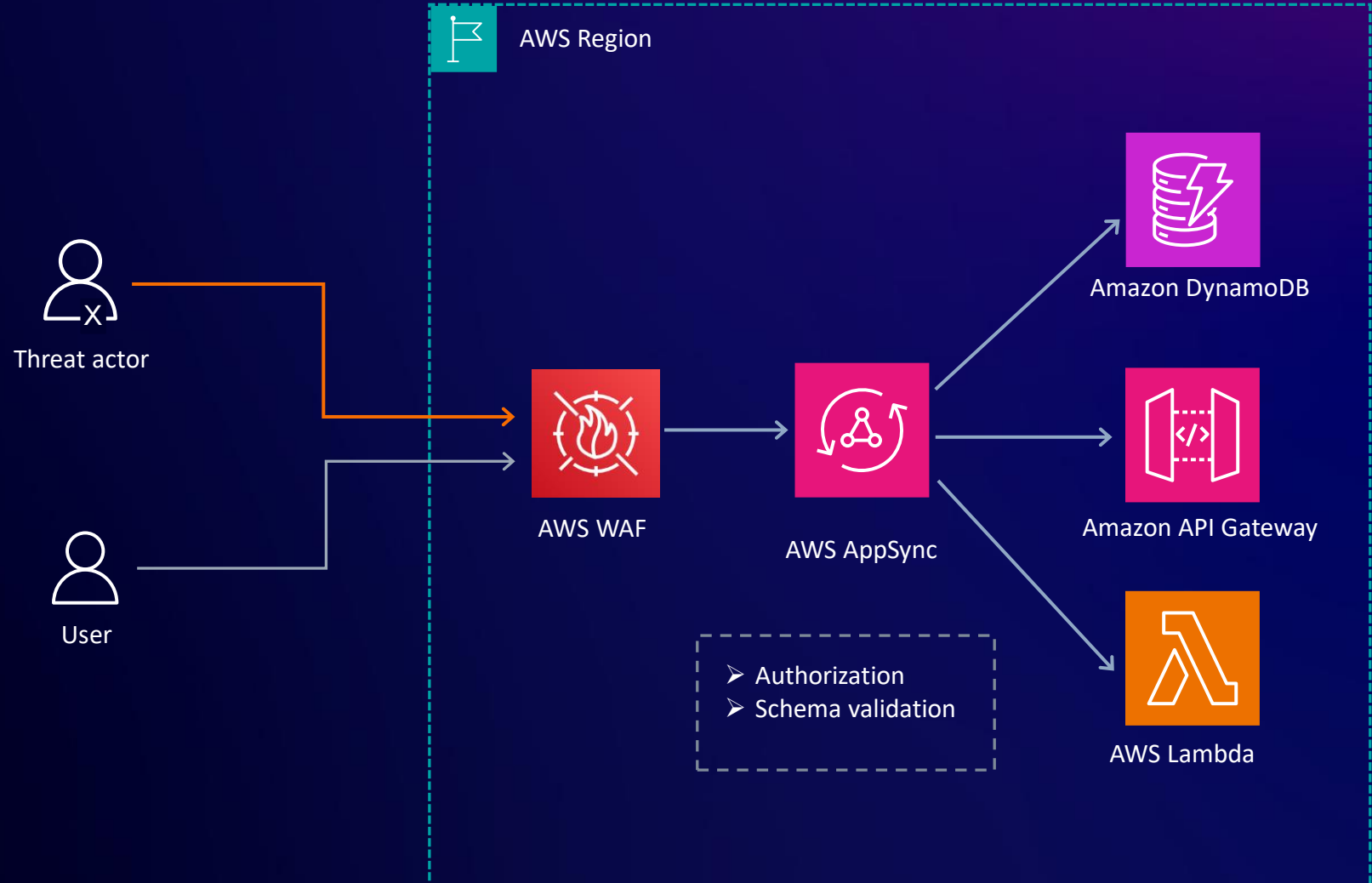


AWS AppSync

Fully managed GraphQL service



Implement GraphQL API security best practices



AWS WAF

protects different application endpoints

Web applications and microservices



AWS Application Load Balancer



AWS App Runner

Serverless applications



Amazon API Gateway



Amazon AppSync

Authentication and authorization

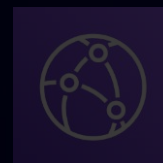


Amazon Cognito



Amazon Verified Access

Web accelerated applications



Amazon CloudFront

Authentication with Amazon Cognito user pools



Amazon Cognito user pools

Fully managed customer identity and access management



Blog post on how to protect Amazon Cognito user pool with AWS WAF



User



Sign in with your username and password

Username

Password

[Forgot your password?](#)

Sign in

Need an account? [Sign up](#)

Cognito hosted UI

- User creation: /signup
- Sign-in: /login
- Account recovery: /forgotPassword



AWS Region



Amazon Cognito



User



Mobile client



AWS Region



Amazon Cognito

Cognito public API:

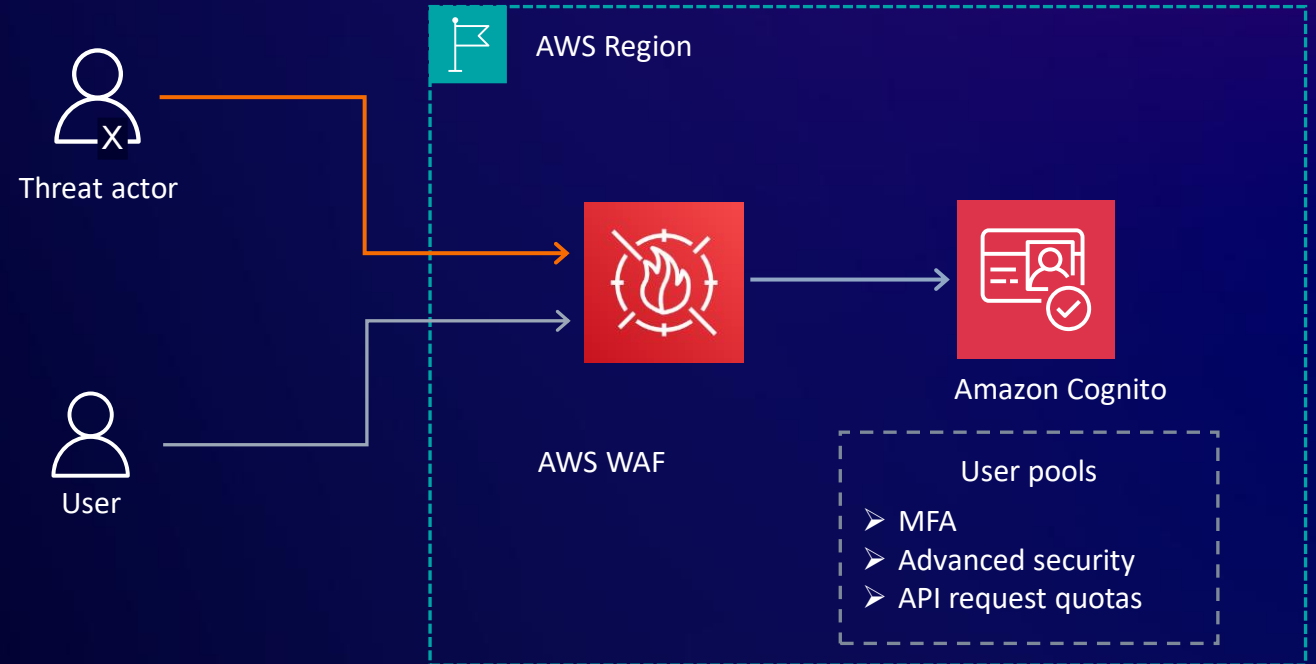
- User creation: signup
- Sign-in: initiateAuth
- Account recovery: forgotPassword

Authentication with Amazon Cognito user pools



Amazon Cognito user pools

Fully managed customer identity and access management



Authorization with AWS Verified Access

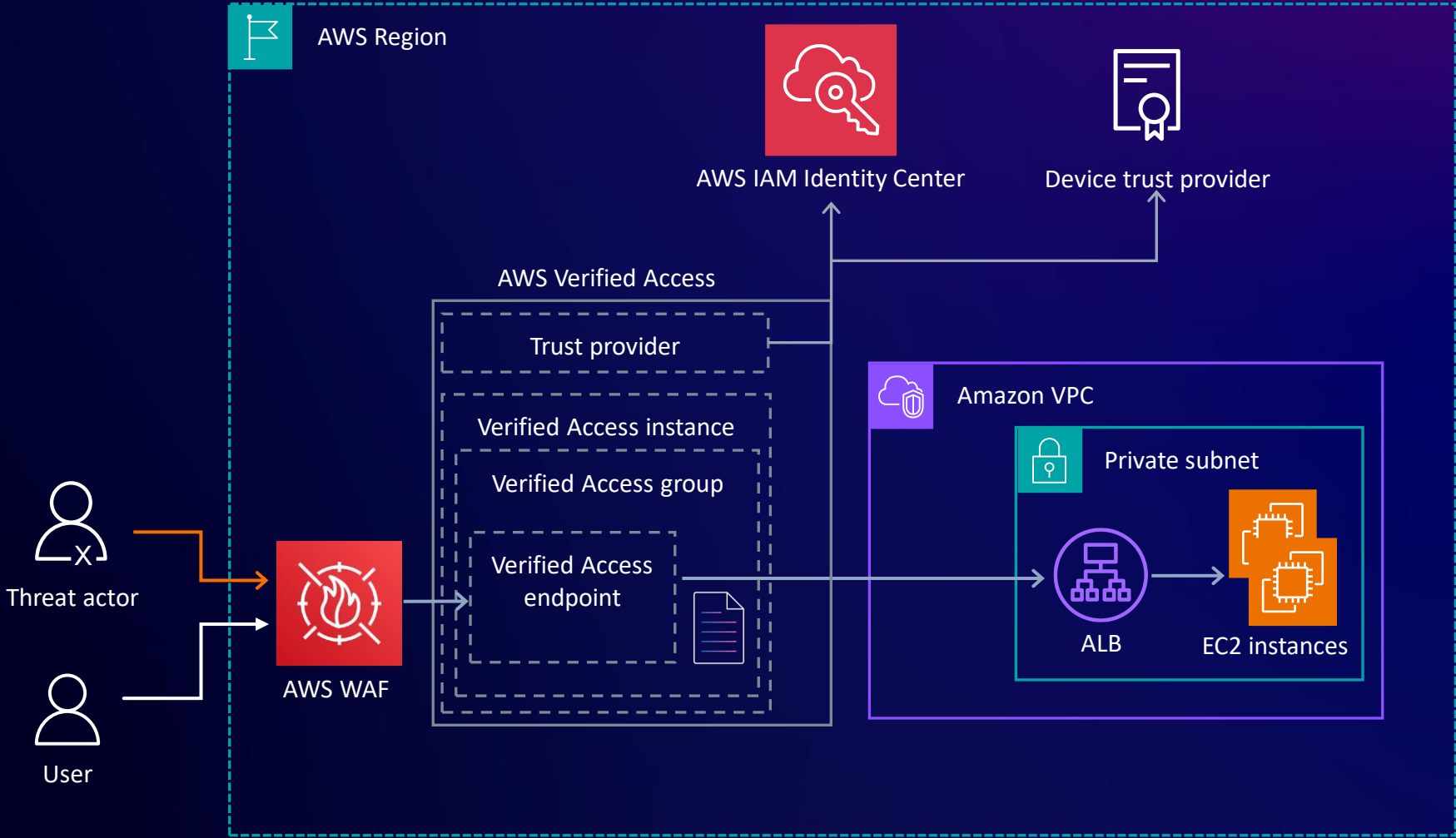


AWS Verified Access

Provide secure access to corporate applications without a VPN.



Provide secure access with Zero Trust and AWS WAF using AWS Verified Access



AWS WAF

protects different application endpoints

Web applications and microservices

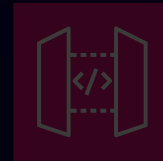


AWS Application Load Balancer



AWS App Runner

Serverless applications

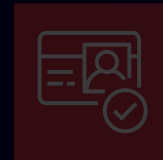


Amazon API Gateway



Amazon AppSync

Authentication and authorization



Amazon Cognito



Amazon Verified Access

Web accelerated applications



Amazon CloudFront

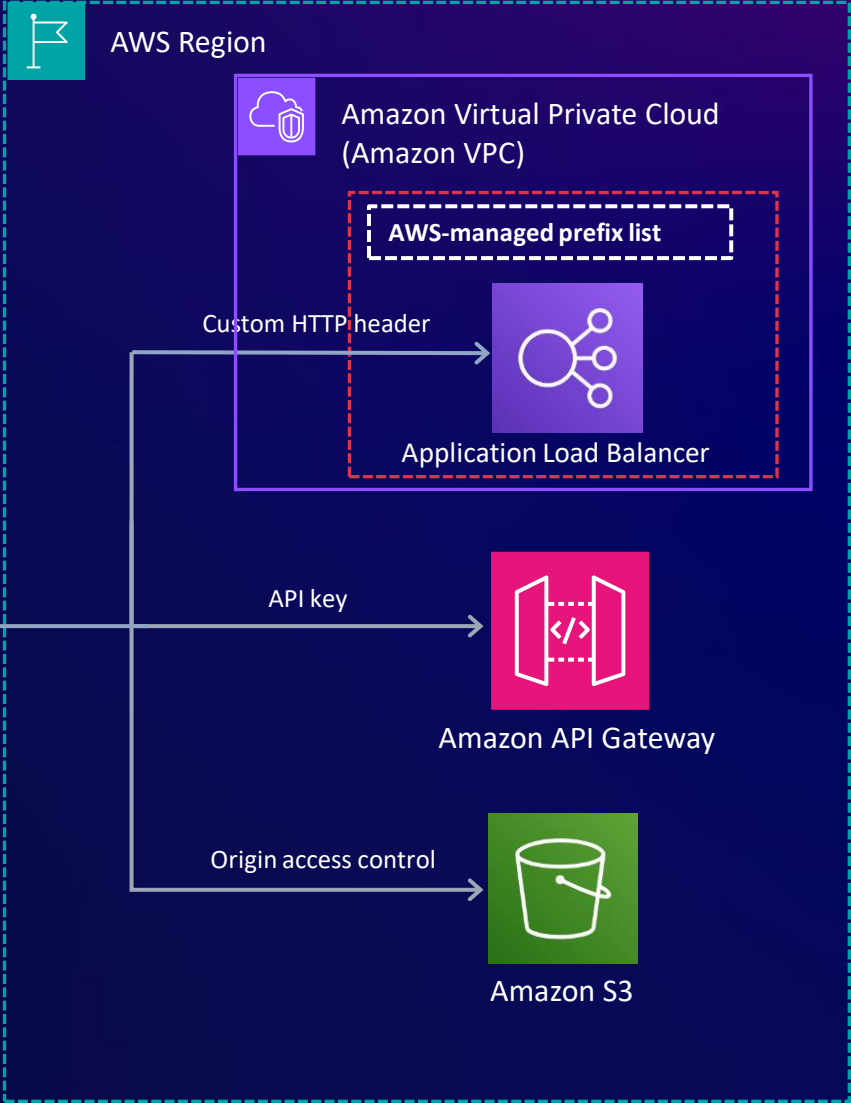
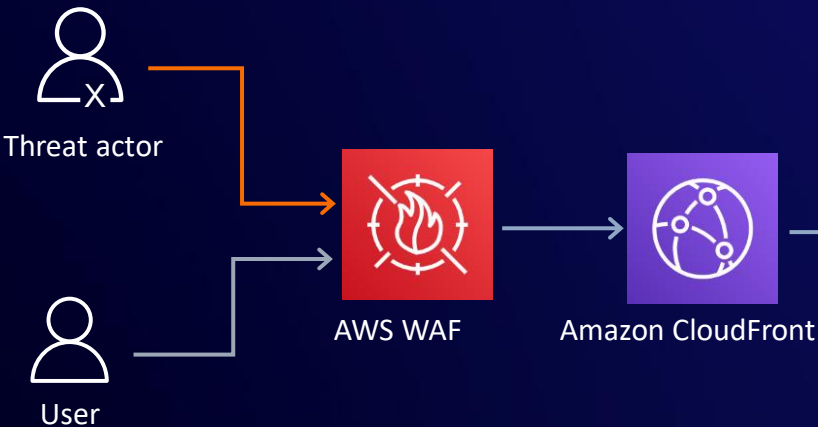
Secure your application perimeter with Amazon CloudFront



Amazon CloudFront
content delivery network



Blog post on how to accelerate your
websites using Amazon CloudFront and AWS
WAF



AWS WAF

protects different application endpoints

Web applications and microservices

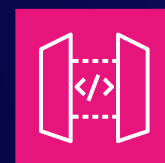


AWS Application Load Balancer



AWS App Runner

Serverless applications



Amazon API Gateway



Amazon AppSync

Authentication and authorization

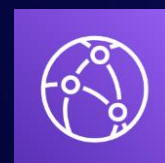


Amazon Cognito



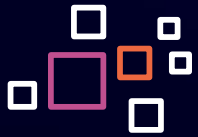
Amazon Verified Access

Web accelerated applications



Amazon CloudFront

Let's build an example AWS WAF configuration



Configurations may vary
by application type

**DEFAULT
ACTION**

Default action is set to
ALLOW in this example



Rules are processed in
priority order



Limit the number of requests
sent to paid rule groups

Blocked lists



Permanently deny access based on geo locations
Eg: block users based out of certain countries for AWS Verified Access endpoints.

Limit requests on a body size
Eg: block request based on sizes for your serverless endpoints.

Deny requests with missing headers
Eg: If your microservice endpoint is expecting specific headers .



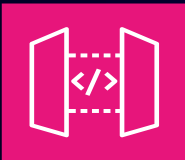
Amazon AppSync



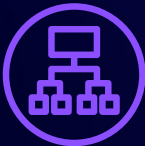
Amazon Verified Access



Amazon Cognito



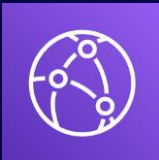
Amazon API Gateway



ALB



AWS AppRunner



Amazon CloudFront

IP reputation rule groups



Learn more about IP reputation rule groups



Learn more about Amazon internal threat intelligence



Blocked lists

IP reputation lists

Amazon IP reputation list managed rule group

Eg: block IP addresses typically associated with bots or other threats including DDoS.

Anonymous IP list managed rule group

Eg: block IP addresses from Tor nodes, temporary proxies and masking services.



Amazon AppSync



Amazon Verified Access



Amazon Cognito



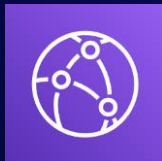
Amazon API Gateway



ALB



AWS AppRunner



Amazon CloudFront



Baseline rulegroups



Learn more about
Baseline rule groups

Core rule set managed rule group

Eg: block high risk and commonly occurring vulnerabilities described in OWASP Top 10 publication

Known Bad Inputs managed rule group

Eg: block requests associated with exploitation or discovery of vulnerabilities.

Admin protection managed rule groups

Eg: block requests that seek access to exposed administrative pages



Blocked lists

IP reputation lists

Baseline rule groups



Amazon
AppSync



Amazon Verified
Access



Amazon
Cognito



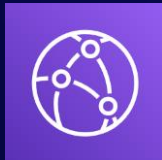
Amazon API
Gateway



ALB



AWS
AppRunner



Amazon
CloudFront



Use case specific rule groups



Learn more about use case
specific rule groups

SQL database managed rule group

Linux/POSIX/Windows operating system managed rule group

PHP application managed rule group

WordPress application managed rule group



Amazon
AppSync



Amazon Verified
Access



Amazon
Cognito



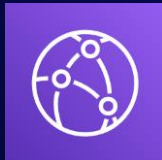
Amazon API
Gateway



ALB



AWS
AppRunner



Amazon
CloudFront



Blocked lists

IP reputation lists

Baseline rule groups

Use case specific rule groups



Rate-based rules



Blog post on benefits of using rate based rules



Blog post on using CAPTCHA with rate based rules



Blog post on types of rate based rules

Rate limit on IP as key

Eg : block http floods on your web application endpoints like ALB.

Rate limit on request type

Eg: limit the number of POST requests on AWS App runner.

Rate limit to render CAPTCHA

Eg: Interrogate requests made from a suspicious user on Amazon CloudFront



Blocked lists

IP reputation lists

Baseline rule groups

Use case specific rule groups

Rate based rules



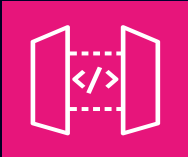
Amazon AppSync



Amazon Verified Access



Amazon Cognito



Amazon API Gateway



ALB



AWS AppRunner



Amazon CloudFront



Allowed lists

Allowed Sources

Eg: using AWS WAF to allow trusted traffic to your endpoint.



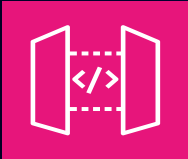
Amazon AppSync



Amazon Verified Access



Amazon Cognito



Amazon API Gateway



ALB



AWS AppRunner



Amazon CloudFront



Blocked lists

IP reputation lists

Baseline rule groups

Use case specific rule groups

Rate based rules

Allowed lists



Intelligent threat mitigation rules



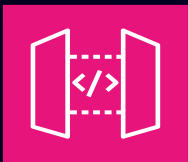
More on AWS Bot Control

Bot Control rule groups

AWS WAF offers two levels of protection- common and targeted rule groups with included ML capabilities.



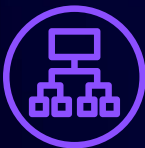
Amazon Cognito



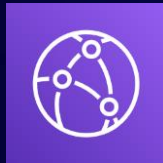
Amazon API Gateway



AWS AppRunner



ALB



Amazon CloudFront



Blocked lists

IP reputation lists

Baseline rule groups

Use case specific rule groups

Rate based rules

Allowed lists

AWS Bot Control



Intelligent threat mitigation rules



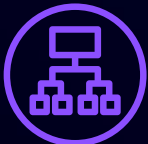
More on AWS Fraud Control

Fraud Control rule groups

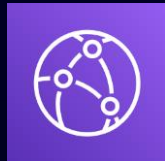
AWS WAF Fraud offerings help customers to mitigate fraudulent account take over attempts on login pages and account creation attempts on signup pages.



AWS AppRunner



ALB



Amazon CloudFront



Blocked lists

IP reputation lists

Baseline rule groups

Use case specific rule groups

Rate based rules

Allowed lists

AWS Bot Control

AWS Fraud Control



Summary

AWS WAF

protects different application endpoints



AWS WAF

Web applications and
microservices



Application
Load Balancer



AWS App Runner

Serverless applications



Amazon API
Gateway



Amazon AppSync

Authorization and
Authentication services

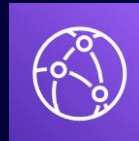


AWS Verified
Access



Amazon Cognito

Web accelerated
applications



Amazon CloudFront

AWS WAF

protects from a variety of threats



OWASP Top 10 & CVEs



Denial of Service



Application specific threats



Common bot threats



Targeted bot mitigation



Account takeover



Account creation fraud

Secure content delivery at re:Invent

Monday, 11/27

Workshop
11:30 AM @MGM Grand 111
NET308-R | Get hands-on
with fraud prevention using
AWS WAF

Breakout
12:00 PM @WYN Lafleur 2
NET321 | How to control
bots and help prevent
account fraud using AWS
WAF

Chalk talk
12:00 PM @WYN Latour 5
NET209 | Optimize website
performance for SEO with
Amazon CloudFront

Tuesday, 11/28

Chalk talk
11:30 AM @CSF Forum 101
NET 210 | Securing your
applications against web
threats with AWS WAF

Workshop
11:30 AM @WYN Cristal 3
NET308-R1 | Get hands-on
with fraud prevention using
AWS WAF

Breakout
1:00 PM @WYN Lafite 9
NET 327 | Improve web
application performance using
AWS Global Accelerator

Builders
1:00 PM @CSF Alliance 311
NET309-R | Improve web
application performance with
serverless edge compute

Chalk talk
5:00 PM @CSF Forum 123
NET307-R | Ask the experts:
Edge compute with Amazon
CloudFront

Wednesday, 11/29

Builders
12:00 PM @CSF Academy 416
NET309-R1 | Improve web
application performance with
serverless edge compute

Chalk talk
12:00 PM @CSF Forum 108
NET307-R1 | Ask the
experts: Edge compute with
Amazon CloudFront

Chalk talk
1:00 PM @MGM Boulevard
167
NET 205 | Why is it always
DNS? Ask us anything

Breakout
2:30 PM @CSF Forum 113
NET322 | Evolve your web
application delivery with
Amazon CloudFront

Wednesday, 11/29 cont.

Chalk talk
2:30 PM @CSF Forum 110
NET329 | Secured and
optimized media delivery with
Amazon CloudFront

Builders
2:30 PM @Mandalay Surf D
NET309-R2 | Improve web
application performance
with serverless edge
compute

Chalk talk
4:00 PM @CSF Forum 110
NET 325 | Understanding
false positives in your
application security

Breakout
4:00 PM @CSF Summit 214
NET328 | Live video
streaming with Amazon
CloudFront and Peacock

Wednesday, 11/29 cont.

Breakout
5:30 PM @CSF Forum 121
NET201 | Safeguarding
infrastructure from DDoS
attacks with AWS edge
services

Friday, 12/01

Chalk talk
11:30 AM @CSF Summit
220
NET307-R2 | Ask the
experts: Edge compute with
Amazon CloudFront

Questions about Amazon
CloudFront or AWS Global
Accelerator? Ask the experts
at AWS Global Infrastructure
kiosk at AWS Village

Thank you!

Harith Gaddamanugu

harithg@amazon.com

Igor Kushnirov

ikkushni@amazon.com



Please complete the session
survey in the mobile app

